2026-10-05 Week06 SELinux

SELinux 이해와 기본 관리

> RHCSA Week 06
> SELinux 운영 모드 · 파일 컨텍스트 · 포트 레이블 · Boolean

1. SELinux란?

SELinux는 **Security-Enhanced Linux**의 약자로, 프로그램이 시스템 자원에 접근할 때 보안 정책에 따라 허용 여부를 판단하는 기능이다.

리눅스를 처음 배울 때는 파일 소유자와 그룹, `rwx` 권한으로 접근을 관리한다. 하지만 실제 시스템에서는 파일 권한이 맞는데도 프로그램이 파일을 읽지 못하거나, 특정 포트를 사용하지 못하는 경우가 있다. 이때 확인해야 하는 항목 중 하나가 SELinux다.

SELinux는 파일뿐 아니라 프로세스, 디렉터리, 포트 등에 적용된다. 핵심은 다음과 같다.

"이 프로그램이 이 자원에 접근해서 이 작업을 수행해도 되는가?"

예를 들어 웹 서버는 웹 문서를 읽어 사용자에게 전달해야 한다. 그렇다고 웹 서버가 시스템에 있는 모든 파일을 읽거나 수정할 필요는 없다. SELinux는 웹 서버에 필요한 작업을 허용하고, 정책에서 허용하지 않은 작업을 제한한다.

이렇게 제한하는 이유는 프로그램에 취약점이 생겼을 때 피해가 다른 영역으로 확산되는 것을 줄이기 위해서다. 웹 서버가 공격받더라도 그 프로세스가 접근할 수 있는 범위를 제한하는 것이다.

물론 SELinux가 프로그램의 취약점을 없애 주는 것은 아니다. 파일 권한, 보안 업데이트, 방화벽 등과 함께 사용하는 보안 장치다.

---

2. 일반 파일 권한과 SELinux의 차이

DAC: 사용자와 그룹을 기준으로 판단

기존 리눅스의 파일 권한 체계는 **DAC, 임의 접근 제어**라고 한다.

파일의 소유자, 그룹, 권한 등을 바탕으로 접근을 판단한다. 앞에서 배운 `chmod`, `chown`, ACL이 여기에 해당한다.

```
ls -l index.html
```

출력 예시:

```
-rw-r--r--. root root 120 Oct 5 21:00 index.html
```

이 파일은 소유자에게 읽기·쓰기를 허용하고, 그룹과 다른 사용자에게 읽기를 허용한다.

따라서 일반 권한만 보면 웹 서버의 실행 계정도 파일을 읽을 수 있다. 단, 파일까지 도달하는 상위 디렉터리에도 접근 권한이 있어야 한다.

MAC: 보안 정책을 기준으로 판단

SELinux는 **MAC, 강제 접근 제어**를 구현한다.

파일 소유자가 읽기 권한을 열어 주었더라도, SELinux 정책에서 해당 프로세스의 접근을 허용하지 않으면 거부할 수 있다.

구분	일반 파일 권한(DAC)	SELinux(MAC)
주요 판단 기준	사용자, 그룹, 권한, ACL	프로세스와 자원의 보안 컨텍스트, 정책
관리 명령 예시	chmod, chown, setfacl	semanage, restorecon, setsebool
확인할 질문	이 계정에 접근 권한이 있는가?	이 프로세스에 이 작업이 허용되는가?

Enforcing 상태에서는 두 조건을 모두 충족해야 한다.

- 파일 권한이 맞아도 SELinux 정책 때문에 거부될 수 있다.
- SELinux 설정이 맞아도 일반 파일 권한이 부족하면 실패할 수 있다.
- 두 조건이 맞더라도 서비스 자체 설정에 의해 거부될 수 있다.

따라서 접근 오류가 발생했다고 `chmod 777`부터 실행하면 안 된다. 일반 권한의 문제인지, SELinux의 문제인지, 서비스 설정의 문제인지 구분해야 한다.

---

3. SELinux는 무엇을 보고 판단할까?

프로세스와 자원에는 컨텍스트가 있다

SELinux는 프로세스와 자원을 구분하기 위해 **보안 컨텍스트(Security Context)**를 사용한다. 흔히 라벨 또는 레이블이라고도 부른다.

파일의 컨텍스트는 다음 명령으로 확인한다.

```
ls -Z /var/www/html/index.html
```

출력 예시:

```
system_u:object_r:httpd_sys_content_t:s0 /var/www/html/index.html
```

컨텍스트는 다음 구조로 구성된다.

```
사용자:역할:타입:레벨
```

필드	예시	의미
사용자	system_u	SELinux 정책상의 사용자
역할	object_r	컨텍스트의 역할
타입	httpd_sys_content_t	대상의 종류를 구분하는 값
레벨	s0	보안 수준과 관련된 값

SELinux 사용자와 리눅스 로그인 사용자는 같은 개념이 아니다. 이번 범위에서는 각 필드의 위치를 이해하고, 특히 **세 번째 필드인 타입**을 확인할 수 있으면 된다.

타입과 도메인

타입은 파일이나 프로세스가 어떤 성격을 갖는지 나타낸다. 프로세스의 타입은 **도메인**이라고도 부른다.

웹 서버와 관련된 대표적인 예시는 다음과 같다.

대상	타입
Apache 웹 서버 프로세스	httpd_t
일반적인 읽기용 웹 콘텐츠	httpd_sys_content_t
웹 서비스용 포트	http_port_t

이름은 비슷하지만 적용 대상이 다르다.

`httpd_sys_content_t`는 파일에 사용하는 타입이고, `http_port_t`는 포트에 사용하는 타입이다. 둘을 서로 바꿔 쓰면 안 된다.

SELinux 정책은 이런 타입 사이에서 어떤 동작을 허용할지 정한다. 이를 **Type Enforcement, 타입 기반 접근 제어**라고 한다.

예를 들어 웹 서버 프로세스가 웹 콘텐츠를 읽는 동작은 허용하되, 다른 서비스의 데이터에 접근하는 동작은 제한하는 식이다. 파일을 읽는 권한과 수정하는 권한도 구분하므로, 웹 콘텐츠 타입을 설정했다고 쓰기까지 모두 허용되는 것은 아니다.

조회 명령

```
# 파일의 컨텍스트
ls -Z /var/www/html/index.html

# 디렉터리 자체의 컨텍스트
ls -Zd /var/www/html

# 실행 중인 httpd 프로세스의 컨텍스트
ps -ZC httpd
```

`ls -Z 디렉터리`는 일반적으로 디렉터리 안의 항목을 보여 준다. **디렉터리 자체를 확인하려면 `-d`를 함께 사용한다.**

`ps -ZC httpd`는 httpd가 실행 중일 때 확인할 수 있다.

---

4. SELinux 운영 모드

SELinux의 상태는 크게 Enforcing, Permissive, Disabled로 구분한다.

Enforcing

정책을 실제로 적용하는 모드다. 정책에 어긋나는 접근을 차단한다.

정상적인 운영과 실습 완료 시에는 보통 이 상태를 기준으로 확인한다.

Permissive

정책을 검사하지만 SELinux 위반을 이유로 접근을 차단하지 않는다. 대신 진단에 사용할 거부 기록을 남긴다.

문제의 원인을 조사할 때 사용할 수 있다. 다만 일반 파일 권한이나 서비스 자체의 접근 제한까지 해제되는 것은 아니다.

Disabled

SELinux가 비활성화된 상태다. Permissive와 다르다.

`setenforce`는 활성화된 SELinux의 Enforcing과 Permissive를 전환하는 명령이다. Disabled 상태를 이 명령만으로 활성화할 수는 없다.

현재 상태 확인

```
getenforce
```

출력 예시:

```
Enforcing
```

조금 더 자세한 정보는 다음 명령으로 확인한다.

```
sestatus
```

현재 모드 변경

```
# Permissive로 변경
sudo setenforce 0

# 현재 상태 확인
getenforce

# Enforcing으로 복귀
sudo setenforce 1

# 현재 상태 확인
getenforce
```

기억할 값은 두 개다.

```
0 = Permissive
1 = Enforcing
```

`setenforce`는 현재 상태를 바꾸는 명령이다. 다음 부팅에 사용할 설정 파일까지 수정하지는 않는다.

재부팅 후에도 유지하기

부팅 시 기본 모드는 `/etc/selinux/config`에서 설정한다.

```
sudo vi /etc/selinux/config
```

Enforcing으로 시작하려면 다음과 같이 설정한다.

```
SELINUX=enforcing
SELINUXTYPE=targeted
```

- `SELINUX`는 운영 모드다.
- `SELINUXTYPE`은 사용할 정책 종류다.
- RHEL의 일반적인 기본 정책은 `targeted`다.

파일을 수정해도 현재 모드가 즉시 바뀌지는 않는다. 지금도 Enforcing으로 적용하려면 별도로 실행한다.

```
sudo setenforce 1
```

재부팅 후에는 다시 확인한다.

```
getenforce
```

RHEL 10에서는 `/etc/selinux/config`에 `SELINUX=disabled`를 넣는 방식으로 비활성화하는 것을 지원하지 않는다. 오래된 자료의 비활성화 절차를 그대로 따라 하지 않도록 구분해야 한다.

부팅 커널 인수에 따라 설정이 재정의될 수도 있으므로, 최종 상태는 조회 명령으로 확인한다.

---

5. 파일 컨텍스트 관리

파일 컨텍스트를 관리할 때는 두 가지를 구분해야 한다.

1. **현재 파일에 실제로 붙어 있는 라벨**
2. **그 경로에 어떤 라벨을 사용하도록 등록했는지에 대한 규칙**

`ls -Z`는 첫 번째를 확인한다.

`semanage fcontext`는 두 번째를 관리한다.

기본 경로의 라벨 복원: restorecon

`/var/www/html`처럼 정책에 기본 용도가 등록된 경로가 있다.

그 안의 파일이 잘못된 컨텍스트를 가지고 있다면 `restorecon`으로 경로 규칙에 맞게 복원한다.

```
sudo restorecon -v /var/www/html/index.html
```

디렉터리와 하위 항목을 함께 처리하려면 다음과 같이 실행한다.

```
sudo restorecon -Rv /var/www/html
```

- `R`: 하위 디렉터리와 파일까지 처리
- `v`: 변경 내용 표시

`restorecon`은 모든 파일을 웹 콘텐츠 타입으로 바꾸는 명령이 아니다. **지정한 경로에 등록된 규칙을 찾아 그 규칙에 맞는 라벨을 적용한다.**

이미 올바른 라벨이라면 변경 출력이 없을 수 있다.

새로운 경로의 규칙 등록: semanage fcontext

기본 웹 경로 대신 `/srv/selinux10`을 웹 콘텐츠 용도로 사용한다고 가정하자.

이 경우에는 해당 경로의 용도를 먼저 등록하고, 실제 라벨에 적용해야 한다.

```
sudo semanage fcontext -a -t httpd_sys_content_t \
  '/srv/selinux10(/.*)?'
```

이 명령은 경로 규칙을 추가한다.

- `a`: 새 규칙 추가
- `t`: 적용할 타입 지정
- `'/srv/selinux10(/.*)?'`: 규칙을 적용할 경로 패턴

패턴 뒤의 `(/.*)?`는 디렉터리 자체와 그 아래 항목을 포함하기 위해 사용한다. 따옴표까지 함께 입력한다.

등록 후 실제 파일과 디렉터리에 적용한다.

```
sudo restorecon -Rv /srv/selinux10
```

결과를 확인한다.

```
ls -Zd /srv/selinux10
ls -Z /srv/selinux10/index.html
```

컨텍스트의 타입이 `httpd_sys_content_t`인지 확인하면 된다. `system_u`, `unconfined_u` 같은 앞부분은 파일의 생성 과정과 환경에 따라 다를 수 있다.

규칙 등록과 실제 적용은 별도 작업이다.

```
semanage fcontext → 경로별 라벨 규칙 등록
restorecon        → 실제 파일에 규칙 적용
```

등록된 규칙 조회와 수정

전체 파일 컨텍스트 규칙:

```
sudo semanage fcontext -l
```

직접 추가하거나 변경한 로컬 규칙:

```
sudo semanage fcontext -l -C
```

같은 경로 패턴의 규칙이 이미 있다면 `-a` 대신 `-m`으로 수정한다.

```
sudo semanage fcontext -m -t httpd_sys_content_t \
  '/srv/selinux10(/.*)?'

sudo restorecon -Rv /srv/selinux10
```

chcon과의 차이

`chcon`은 실제 파일의 컨텍스트를 직접 바꾼다.

```
sudo chcon -t httpd_sys_content_t /srv/selinux10/index.html
```

하지만 이 명령은 해당 경로의 기본 규칙을 등록하지 않는다. 따라서 이후 `restorecon`이나 파일 시스템 재라벨링이 수행되면 등록된 규칙에 맞춰 달라질 수 있다.

여기서 "chcon은 일시적이다"라는 표현을 **"재부팅하면 반드시 사라진다"**로 이해하면 안 된다. 단순 재부팅 후에도 남을 수 있지만, 정책에 따라 라벨을 복원할 때 유지되지 않을 수 있다는 의미다.

지속적으로 관리할 경로라면 `semanage fcontext`로 규칙을 등록하고 `restorecon`으로 적용하는 방식을 사용한다.

파일을 옮겼을 때도 확인한다

같은 파일 시스템 안에서 `mv`로 이동한 파일은 기존 라벨을 유지할 수 있다. 따라서 홈이나 임시 디렉터리에서 웹 경로로 옮긴 파일이 새 용도에 맞지 않는 타입을 갖고 있을 수 있다.

복사도 새 파일 생성 여부와 보존 옵션에 따라 결과가 달라진다. "이 경로에 넣었으니 자동으로 맞을 것"이라고 가정하지 말고 확인한다.

```
ls -Z /var/www/html/index.html
sudo restorecon -v /var/www/html/index.html
```

---

6. SELinux 포트 레이블 관리

서비스가 사용하는 포트에도 SELinux 타입이 있다.

웹 서버가 기본 포트가 아닌 다른 포트에서 대기하도록 설정했다면, SELinux에서도 그 포트가 웹 서비스에 적절한 타입인지 확인해야 한다.

등록된 포트 조회

```
sudo semanage port -l
```

웹 서비스용 포트 타입만 확인하려면 다음과 같이 조회한다.

```
sudo semanage port -l | grep -w http_port_t
```

출력에는 타입, 프로토콜, 포트 번호가 표시된다. 등록된 번호는 시스템 정책과 로컬 설정에 따라 달라질 수 있다.

새로운 포트 등록

TCP 3131에 별도 항목이 없고, 이를 웹 서비스용으로 추가한다고 가정하자.

```
sudo semanage port -a -t http_port_t -p tcp 3131
```

- `a`: 새 항목 추가
- `t http_port_t`: 웹 서비스용 타입 지정
- `p tcp`: TCP 프로토콜 지정
- `3131`: 포트 번호

로컬 변경 내용을 확인한다.

```
sudo semanage port -l -C
```

`semanage port`로 등록한 설정은 재부팅 후에도 유지된다.

이미 등록되어 있는 경우

`already defined` 오류가 나오면 기존 타입부터 확인한다.

- 이미 `http_port_t`라면 같은 항목을 추가할 필요가 없다.
- 다른 타입이라면 기존 용도와 사용 서비스를 확인한다.
- 변경이 필요한 상황에서만 `m`을 사용한다.

```
sudo semanage port -m -t http_port_t -p tcp 3131
```

오류가 났다는 이유만으로 `-a`를 `-m`으로 바꿔 실행하면 다른 서비스에 영향을 줄 수 있다.

포트 레이블과 방화벽은 다르다

웹 서비스가 외부 요청을 받으려면 다음 조건을 각각 확인해야 한다.

확인 항목	의미
서비스 설정과 실행 상태	프로그램이 실제 해당 포트에서 대기하는가?
SELinux 포트 타입	그 서비스가 해당 포트를 사용할 수 있는가?
방화벽과 네트워크	외부 요청이 서버까지 도달할 수 있는가?

실제로 대기 중인 포트는 다음 명령으로 확인한다.

```
sudo ss -lntp
```

`semanage port`는 서비스를 시작하지 않는다. 방화벽 포트를 열어 주는 명령도 아니다.

반대로 방화벽에서 포트를 허용했다고 SELinux 포트 타입까지 설정되는 것도 아니다.

---

7. Boolean 설정

Boolean은 SELinux 정책에서 제공하는 **on/off 형태의 설정 항목**이다.

서비스의 특정 동작을 허용해야 할 때, 정책을 직접 작성하는 대신 준비된 Boolean을 조정할 수 있다.

현재 값 확인

예를 들어 웹 서버 프로세스가 네트워크 연결을 시작하는 동작과 관련된 Boolean은 다음과 같이 확인한다.

```
getsebool httpd_can_network_connect
```

출력 예시:

```
httpd_can_network_connect --> off
```

웹 서버 관련 항목들을 조회하려면 다음과 같이 실행한다.

```
getsebool -a | grep '^httpd_'
```

설명을 함께 확인할 때는 다음 명령을 사용할 수 있다.

```
sudo semanage boolean -l | grep httpd_can_network_connect
```

현재 값만 변경

```
sudo setsebool httpd_can_network_connect on
```

확인:

```
getsebool httpd_can_network_connect
```

- `P`가 없으면 현재 값만 변경한다. 재부팅하면 저장된 값으로 돌아간다.

이때 저장된 값이 원래 `on`이었다면 다시 `on`이 된다. **"-P가 없으면 재부팅 후 무조건 off"는 잘못된 설명이다.**

영구 변경

```
sudo setsebool -P httpd_can_network_connect on
```

- `P`를 사용하면 재부팅 후에도 유지할 값을 저장하고 현재 값에도 적용한다. 처리에 시간이 걸릴 수 있으므로 명령이 완료될 때까지 기다린다.

필요에 따라 영구적으로 끄려면 다음과 같이 실행한다.

```
sudo setsebool -P httpd_can_network_connect off
```

이 Boolean이 의미하는 것

외부 사용자가 웹 서버에 접속하는 것과, 웹 서버가 다른 서버로 연결을 시작하는 것은 서로 다르다.

`httpd_can_network_connect`는 후자와 관련된 설정이다. 이를 켠다고 웹 서버가 자동으로 시작되거나, 외부에서 들어오는 방화벽 포트가 열리는 것은 아니다.

문제가 발생했다고 관련 Boolean을 전부 켜기보다는, 서비스가 어떤 작업을 해야 하는지 확인하고 필요한 항목을 선택한다.

---

8. SELinux 문제 확인 순서

서비스가 동작하지 않는다고 바로 SELinux 문제로 단정하면 안 된다. 다음 순서로 범위를 좁히면 된다.

① 현재 모드 확인

```
getenforce
```

현재 Enforcing인지 확인한다. Permissive에서도 동일하게 실패한다면 일반 권한이나 서비스 설정 등 다른 원인도 함께 살펴본다.

② 일반 권한과 서비스 설정 확인

```
ls -l /경로/파일
```

파일뿐 아니라 상위 디렉터리 접근 권한도 확인한다. 서비스가 올바른 경로와 포트를 사용하도록 설정되어 있는지도 살펴본다.

③ 파일 컨텍스트 확인

```
ls -Z /경로/파일
ls -Zd /경로/디렉터리
```

기본 경로의 라벨이 잘못되었다면 `restorecon`을 사용한다.

새로운 사용자 지정 경로라면 필요한 `fcontext` 규칙이 있는지 확인하고, 등록 후 적용한다.

④ 포트와 Boolean 확인

특정 포트에서 서비스를 시작하지 못한다면 포트 충돌과 서비스 설정을 확인한 뒤 SELinux 포트 타입을 확인한다.

서비스가 다른 시스템으로 연결하지 못한다면 네트워크 상태와 관련 Boolean을 살펴본다.

⑤ 로그 확인

SELinux의 접근 거부 기록은 흔히 **AVC 메시지**라고 부른다.

```
sudo ausearch -m AVC,USER_AVC -ts recent
```

최근 거부 기록에서 어떤 프로세스가 어떤 대상에 무슨 작업을 하다가 거부되었는지 확인한다. 로그 수집 상태 등에 따라 기록이 보이지 않을 수 있으므로, 출력이 없다는 이유만으로 SELinux와 무관하다고 단정하지 않는다.

서비스 로그도 함께 확인한다. 다음은 httpd를 사용하는 경우의 예시다.

```
sudo journalctl -u httpd --since '10 minutes ago'
```

처음부터 새로운 정책을 만들려고 하기보다 **라벨 오류, 포트 타입, 관련 Boolean, 서비스 설정**부터 확인하는 것이 좋다.

---

9. 이번 주 핵심 정리

작업	명령 또는 설정
현재 모드 확인	getenforce
상세 상태 확인	sestatus
현재 Permissive 전환	setenforce 0
현재 Enforcing 전환	setenforce 1
부팅 시 기본 모드 설정	/etc/selinux/config
파일 컨텍스트 확인	ls -Z

작업	명령 또는 설정
디렉터리 자체 컨텍스트 확인	ls -Zd
프로세스 컨텍스트 확인	ps -ZC 프로세스명
파일 컨텍스트 규칙 관리	semanage fcontext
경로 규칙에 맞게 라벨 적용	restorecon
포트 타입 관리	semanage port
Boolean 확인	getsebool
Boolean 현재 값 변경	setsebool
Boolean 영구 변경	setsebool -P

마지막으로 다음 네 가지를 구분할 수 있으면 된다.

- **모드:** 현재 정책 위반을 차단하는 상태인가?
- **파일 컨텍스트:** 파일이 용도에 맞는 타입을 가지고 있는가?
- **포트 레이블:** 서비스가 사용할 포트의 타입이 적절한가?
- **Boolean:** 서비스에 필요한 추가 동작이 정책에서 허용되어 있는가?

특히 파일 컨텍스트는 **규칙 등록** → **실제 적용** → **결과 확인**, 모드와 Boolean은 **현재 상태** → **영구 설정** → **재부팅 후 확인**을 구분해서 기억한다.